

Cyber Threat Intelligence

Executive Briefing

Report Date: July 02, 2026

Generated: 2026-07-02 16:57 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
5	7	7	1	20

2. Executive Summary

This briefing for July 02, 2026, details the analysis of 20 identified vulnerabilities categorized as follows: 5 Critical, 7 High, 7 Medium, and 1 Low. The current organizational risk posture is evaluated as High, characterized by significant exposure to exploit vectors that could lead to unauthorized system access and privilege escalation. The highest priority threat is CVE-2026-53943, 'Cache-Poisoning XSS in Ghost Frontend,' due to its potential for widespread impact on user session integrity and delivery of malicious payloads. We recommend an immediate transition to a reactive remediation posture, mandating the application of security patches to all affected infrastructure systems without delay. Executive oversight is required to ensure that departmental resources are prioritized to complete these mitigations within the designated recovery time objectives.

3. Critical Action List

- CVE-2026-44935: Initiate emergency patch deployment for Rancher Fleet instances to resolve cross-namespace secret disclosure within 24 hours.
- CVE-2026-53943: Implement temporary WAF-level filtering for Ghost frontend traffic and apply vendor-supplied hotfix within 24 hours to neutralize cache-poisoning risks.
- CVE-2026-44939: Disable untrusted YAML processing inputs immediately and execute core Rancher update within 48 hours to mitigate command injection vectors.
- CVE-2026-41053: Audit and restrict GitHub App authentication team memberships to align with the principle of least privilege within 72 hours.
- CVE-2026-41052: Perform a comprehensive audit of all Project Owner accounts and apply necessary kernel-level security hardening within 72 hours to prevent host escalation.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-44935	Cross-Namespace Secret Disclosure...	7.7	High	89/100	CWE-863
CVE-2026-53943	Cache-Poisoning XSS in Ghost Fron...	9.6	Critical	86/100	CWE-524
CVE-2026-44939	Command Injection in Rancher YAML...	9.1	Critical	86/100	CWE-95
CVE-2026-41053	GitHub App Auth Membership Expans...	8.8	High	79/100	CWE-303
CVE-2026-41052	Rancher Project Owner Host Escala...	9.1	Critical	76/100	CWE-305
CVE-2026-50143	Token Leak via MCP Path Injection	9.1	Critical	73/100	CWE-918
CVE-2026-50138	WebDAV Access Control Bypass in g...	9.1	Critical	73/100	CWE-284
CVE-2026-53712	SCRAM Auth Downgrade in OnGres	7.4	High	68/100	CWE-636
CVE-2026-50151	Credential Forwarding in oras-go	7.5	High	68/100	CWE-918
CVE-2026-44937	Regex Injection in Fleet Webhook	7.5	High	68/100	CWE-345
CVE-2026-9795	Privilege Escalation in Keycloak	7.1	High	66/100	CWE-266
CVE-2026-50163	Arbitrary File Write in oras-go	7.8	High	64/100	CWE-22
CVE-2026-50162	Symlink Traversal Write in oras-go	6.5	Medium	59/100	CWE-73
CVE-2026-48978	Bearer Token Realm Hijacking in o...	6.5	Medium	56/100	CWE-319
CVE-2026-50139	Download Limit Race Condition in ...	3.7	Low	53/100	CWE-362
CVE-2026-45045	IP Spoofing via GoFiber BalancerF...	5.3	Medium	48/100	CWE-290
CVE-2026-44332	Username Enumeration in GoFiber B...	5.3	Medium	48/100	CWE-203
CVE-2026-48824	Mailpit Memory Exhaustion DoS	5.3	Medium	48/100	CWE-770
CVE-2026-44936	SSRF in Rancher Fleet Bundle Read...	5.0	Medium	45/100	CWE-918
CVE-2026-48819	Prototype Pollution in openapi-ts	4.8	Medium	43/100	CWE-1321

5. Detailed Vulnerability Findings

CVE-2026-44935

Finding: Cross-Namespace Secret Disclosure in Fleet

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 89/100 | CWE: CWE-863

MITRE ATT&CK: T1552, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Rancher Fleet is vulnerable to cross-namespace secret disclosure due to unvalidated valuesFrom references within the Helm Deployer. An attacker with control over a specific namespace can define Helm values that reference secrets in other namespaces, which the deployer then inadvertently reads. This allows for the exfiltration of sensitive information

across Kubernetes boundaries.

Proof of Concept (PoC):

An authenticated user with access to a low-privileged namespace creates a Fleet deployment manifest containing a valuesFrom field pointing to a sensitive secret in the 'kube-system' namespace. Rancher Fleet processes the manifest and retrieves the secret data because it performs no validation on the cross-namespace reference. The sensitive secret is then injected into the attacker-controlled container environment for retrieval.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44935>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44935>

CVE-2026-53943

Finding: Cache-Poisoning XSS in Ghost Frontend

CVSS v3.1 Score: 9.6 | Severity: Critical | Urgency Score: 86/100 | CWE: CWE-524

MITRE ATT&CK: T1189, T1505

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

The Ghost frontend is susceptible to a cache-poisoning reflected Cross-Site Scripting (XSS) vulnerability triggered via the x-ghost-preview header. This arises from the application's failure to properly sanitize the input header before reflecting it in the response body or caching it at the edge. A remote attacker can craft malicious requests to inject arbitrary scripts that are served to subsequent users from the cache.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to the Ghost frontend with a malicious payload injected into the x-ghost-preview header. The server processes the header and reflects the unsanitized payload, which is then cached by the reverse proxy. Subsequent visitors are served the cached malicious response, leading to arbitrary JavaScript execution in the context of the user's browser.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53943>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53943>

CVE-2026-44939

Finding: Command Injection in Rancher YAML Parsing

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 86/100 | CWE: CWE-95

MITRE ATT&CK: T1059, T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	High
Scope	Changed

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High

Integrity Impact

High

Availability Impact

High

Description:

Rancher is vulnerable to command injection through unsanitized YAML parameters during processing. This occurs because the application improperly escapes parameters before passing them to system shells or command execution utilities. A malicious actor can provide specially crafted YAML inputs that result in the execution of arbitrary commands on the server host with elevated privileges.

Proof of Concept (PoC):

An attacker with high privileges submits a malformed YAML configuration containing shell injection syntax (e.g., ; command_to_execute) within a specific parameter field. The Rancher backend passes this unsanitized input directly to a system process execution routine. The server subsequently interprets and executes the attacker's shell commands, leading to full system compromise.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44939>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44939>

CVE-2026-41053**Finding: GitHub App Auth Membership Expansion**

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-303

MITRE ATT&CK: T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Rancher's GitHub App authentication provider contains a flaw where team membership checks are overly expansive, incorrectly inheriting group rights. The vulnerability stems from recursive membership expansion logic that fails to respect nested team boundaries properly when calculating authorization. This permits users who are members of sub-teams to gain access rights assigned to larger organizational groups.

Proof of Concept (PoC):

A user with minimal access in a GitHub sub-team authenticates into Rancher using the affected provider. Rancher's auth logic fetches the list of associated teams but fails to distinguish between parent teams and child teams during the expansion phase. The user is consequently granted the administrative permissions associated with the root-level organizational team, enabling unauthorized cluster management.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-41053>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-41053>

CVE-2026-41052**Finding: Rancher Project Owner Host Escalation**

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 76/100 | CWE: CWE-305

MITRE ATT&CK: T1068, T1611

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	High
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Rancher contains a vulnerability that allows a user with Project Owner permissions to escalate privileges to the underlying host. The flaw stems from insufficient isolation between the Rancher project controller and the host node configuration plane during container management. An attacker can leverage this to break out of the container environment and gain full control over the host node.

Proof of Concept (PoC):

An authenticated user with Project Owner access manipulates container deployment specifications through the Rancher API to mount critical host volumes. The rancher controller fails to validate the requested volume configurations against the restricted namespace policy. This permits the attacker to gain code execution on the host machine and effectively escalate their privileges.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-41052>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-41052>

CVE-2026-50143**Finding: Token Leak via MCP Path Injection**

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 73/100 | CWE: CWE-918

MITRE ATT&CK: T1552, T1046

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Apify Model Context Protocol (MCP) server is vulnerable to path authority injection which can lead to the exposure of sensitive Apify tokens. The vulnerability is caused by insufficient validation of user-controlled input paths during the actor communication phase. An attacker can exploit this to force the server to disclose internal credentials to an external destination.

Proof of Concept (PoC):

An unauthenticated remote attacker crafts a malicious request to the MCP server containing a path authority traversal sequence in the target URL. The server fails to sanitize this input, allowing it to interpret the attacker-defined path as a legitimate resource location. This triggers the server to forward authorization tokens to the attacker-controlled endpoint.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50143>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50143>

CVE-2026-50138

Finding: WebDAV Access Control Bypass in goshs

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 73/100 | CWE: CWE-284

MITRE ATT&CK: T1021

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The WebDAV listener in goshs improperly ignores restricted mode flags such as --read-only, --upload-only, and --no-delete. This security failure originates from a configuration processing flaw where the intended enforcement checks are skipped during listener initialization. Consequently, an unauthenticated attacker can perform unauthorized file system modifications regardless of the server's stated deployment constraints.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a DELETE request to the goshs WebDAV endpoint even when --no-delete is enabled. The server's listener logic fails to verify the flag against the incoming request type. This results in the server successfully deleting files on the filesystem, bypassing the intended read-only or restricted access configuration.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50138>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50138>

CVE-2026-53712

Finding: SCRAM Auth Downgrade in OnGres

CVSS v3.1 Score: 7.4 | Severity: High | Urgency Score: 68/100 | CWE: CWE-636

MITRE ATT&CK: T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The OnGres SCRAM implementation suffers from a silent channel-binding authentication downgrade when unsupported certificate algorithms are negotiated. The flaw exists because the client-side authentication library incorrectly falls back to a weaker non-binding mechanism when it encounters an error rather than aborting the connection. An attacker in a man-in-the-middle position can force this downgrade to strip protection from the SCRAM exchange.

Proof of Concept (PoC):

A man-in-the-middle attacker intercepts the SCRAM handshake between the client and the OnGres server and forces an error by presenting an unsupported certificate algorithm. The client, instead of failing, silently transitions to a weaker, non-channel-bound authentication method. The attacker then intercepts the downgraded authentication flow to capture

or impersonate valid user credentials.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53712>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53712>

CVE-2026-50151

Finding: Credential Forwarding in oras-go

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-918

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The oras-go blob upload process is vulnerable to credential forwarding due to unvalidated redirect handling within the Location header. The library automatically follows HTTP redirects without confirming if the new destination belongs to the expected registry, allowing sensitive credentials to be leaked to malicious external endpoints. This poses a significant threat of session hijacking during image transmission.

Proof of Concept (PoC):

An attacker hosts a malicious registry endpoint that responds to a blob upload request with a 302 redirect pointing to their own server. The oras-go library follows the redirect and attaches the Authorization header to the request sent to the attacker's server. This results in the attacker successfully capturing the victim's credentials meant for the legitimate registry.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50151>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50151>

CVE-2026-44937

Finding: Regex Injection in Fleet Webhook

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-345

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Rancher Fleet unauthenticated webhook is vulnerable to Regex Injection through unsanitized repository URL components. Because the incoming URL parameters are processed by regular expressions without proper escaping, an attacker can manipulate the internal regex state. This vulnerability allows an attacker to cause Denial of Service or

potentially bypass access control checks.

Proof of Concept (PoC):

An unauthenticated attacker sends a request to the Fleet webhook containing a highly complex, catastrophic backtracking regex pattern in the repository URL parameter. The server attempts to evaluate the pattern against the input, consuming excessive CPU cycles due to the injection flaw. This triggers a server-side resource exhaustion state, effectively preventing legitimate webhooks from being processed.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44937>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44937>

CVE-2026-9795

Finding: Privilege Escalation in Keycloak

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 66/100 | CWE: CWE-266

MITRE ATT&CK: T1068, T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Keycloak is vulnerable to privilege escalation resulting from improper scope mapping enforcement within the authorization server. The defect allows an authenticated user to request and receive scopes that were not intended for their assigned roles or context. This failure to restrict scope mapping can lead to unauthorized access to downstream resources protected by the Keycloak identity provider.

Proof of Concept (PoC):

An authenticated user with low-level privileges requests an OAuth token while manually specifying sensitive, unauthorized scopes in the request parameters. Keycloak fails to enforce policy-based scope mapping and grants the requested, restricted scopes to the user. The user then utilizes the returned token to access administrative or high-privileged APIs for which they are not authorized.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-9795>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-9795>

CVE-2026-50163

Finding: Arbitrary File Write in oras-go

CVSS v3.1 Score: 7.8 | Severity: High | Urgency Score: 64/100 | CWE: CWE-22

MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High

Integrity Impact

High

Availability Impact

High

Description:

The oras-go tar extraction logic is vulnerable to directory traversal via malicious hardlink entries. The library fails to validate that the Linkname field resolved relative to the working directory remains within the intended extract path. An attacker can exploit this to overwrite critical system files by crafting an archive containing specially formed hardlink references.

Proof of Concept (PoC):

A local attacker provides a malicious OCI artifact containing a tar entry with a hardlink pointing to a sensitive file outside the target directory (e.g., .././etc/passwd). Upon calling the extraction routine, oras-go resolves the path incorrectly and allows the link to be created. This grants the attacker the ability to overwrite or corrupt protected files on the host filesystem.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50163>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50163>

CVE-2026-50162**Finding: Symlink Traversal Write in oras-go**

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-73

MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	None

Description:

The oras-go library is vulnerable to file store write outside the designated working directory when processing symlinks. The root cause is a missing check on the target path of symlink extraction, permitting the tool to follow and write to files outside the root extract directory. This allows an attacker to gain write access to the host's filesystem by distributing a malicious OCI artifact.

Proof of Concept (PoC):

An attacker uploads an OCI artifact to a repository containing a symlink that resolves to a location outside the targeted extraction directory. When a user pulls and extracts this image using an affected version of oras-go, the library follows the symlink. The file content is subsequently written to an arbitrary location on the victim's filesystem, leading to unauthorized modification.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50162>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50162>

CVE-2026-48978**Finding: Bearer Token Realm Hijacking in oras-go**

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 56/100 | CWE: CWE-319

MITRE ATT&CK: T1557, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The oras-go registry client is vulnerable to Bearer token realm hijacking, enabling malicious registries to exfiltrate credentials and refresh tokens. This occurs because the client fails to pin the authentication realm to the original service provider when handling auth challenge responses. An adversary can then supply a fraudulent realm to intercept and exfiltrate authentication data during the registry handshake.

Proof of Concept (PoC):

An attacker creates a malicious OCI registry and tricks a user into authenticating against it. During the handshake, the attacker provides a custom realm and auth challenge that tricks the oras-go client into sending the user's credentials to the attacker's server. The server captures the token and uses it to impersonate the user against the legitimate primary registry.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48978>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48978>

CVE-2026-50139**Finding: Download Limit Race Condition in goshs**

CVSS v3.1 Score: 3.7 | Severity: Low | Urgency Score: 53/100 | CWE: CWE-362

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The goshs application contains a race condition in the share-link token redemption process that allows users to exceed configured download limits. The defect occurs because the increment check and decrement logic for download tokens are not executed atomically during the request processing loop. This allows concurrent requests to bypass the restriction and retrieve files beyond the permitted threshold.

Proof of Concept (PoC):

An unauthenticated remote attacker initiates multiple rapid, concurrent download requests using the same ?token= identifier. The goshs server fails to implement atomic locking on the download counter variable. This causes the race condition to occur, allowing the attacker to download files significantly more times than the server policy intends.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50139>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50139>

CVE-2026-45045

Finding: IP Spoofing via GoFiber BalancerForward

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-290

MITRE ATT&CK: T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The GoFiber framework is vulnerable to IP spoofing within the BalancerForward component due to improper handling of the X-Real-IP header via Header.Add(). The underlying issue stems from allowing untrusted user-supplied headers to override internal proxy state indicators without sanitization. This results in the misidentification of client IP addresses, which can bypass IP-based access controls or logging mechanisms.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP request containing a forged X-Real-IP header to the BalancerForward function. The GoFiber balancer fails to validate or strip existing headers, accepting the user-supplied IP as authoritative. The application logs the attacker's spoofed IP address instead of the true source, effectively bypassing security filters relying on header integrity.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-45045>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-45045>

CVE-2026-44332

Finding: Username Enumeration in GoFiber BasicAuth

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-203

MITRE ATT&CK: T1087

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The GoFiber BasicAuth default authorizer is vulnerable to username enumeration through a timing oracle attack. The root cause is a non-constant time comparison operation when processing authentication credentials against the user database. This enables an unauthenticated attacker to discern valid account identifiers by measuring response latency during login attempts.

Proof of Concept (PoC):

An unauthenticated remote attacker sends multiple authentication requests to the login endpoint using various usernames. The BasicAuth authorizer executes string comparisons that return earlier for incorrect user patterns

compared to valid ones. By analyzing the time variance across multiple requests, the attacker confirms the existence of valid accounts within the system.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44332>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44332>

CVE-2026-48824

Finding: Mailpit Memory Exhaustion DoS

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-770

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

The Mailpit API is vulnerable to memory exhaustion due to insufficient size constraints when parsing unbounded JSON request bodies on multiple endpoints, including /api/v1/messages and /api/v1/tags. This remains a security concern as the application fails to limit input buffer sizes, leading to excessive allocation when processing malicious, oversized payloads. An unauthenticated attacker can exploit this to crash the service and cause a Denial of Service (DoS).

Proof of Concept (PoC):

An unauthenticated remote attacker sends an exceptionally large, multi-megabyte JSON payload to the /api/v1/messages endpoint. The Mailpit backend immediately attempts to parse the full body into memory without proper bounds checking or stream processing. This results in an out-of-memory error, causing the entire Mailpit service to crash and stop accepting new traffic.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48824>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48824>

CVE-2026-44936

Finding: SSRF in Rancher Fleet Bundle Reader

CVSS v3.1 Score: 5.0 | Severity: Medium | Urgency Score: 45/100 | CWE: CWE-918

MITRE ATT&CK: T1046, T1595

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Rancher Fleet is vulnerable to Server-Side Request Forgery (SSRF) in the Bundle Reader component, triggered by an unvalidated Helm repository URL in the fleet.yaml file. This defect occurs because the library does not verify the

destination host against an allowed list before initiating fetch operations. An attacker can exploit this to scan internal network services or access metadata services through the Fleet server.

Proof of Concept (PoC):

An authenticated user creates a fleet.yaml file with a malicious Helm repository URL pointing to an internal-only IP address (e.g., http://169.254.169.254). When Rancher Fleet attempts to process the bundle, the Bundle Reader makes an HTTP request to the internal address. The response from the internal service is potentially processed or logged, confirming the existence and structure of internal network resources.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44936>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44936>

CVE-2026-48819

Finding: Prototype Pollution in openapi-ts

CVSS v3.1 Score: 4.8 | Severity: Medium | Urgency Score: 43/100 | CWE: CWE-1321

MITRE ATT&CK: T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The @hey-api/openapi-ts library is vulnerable to prototype chain substitution within its buildClientParams template. The flaw occurs because the library fails to sanitize user-defined keys, allowing a crafted \$<slot>__proto__ key to overwrite internal object prototypes. This can be weaponized to modify the behavior of the application at runtime, potentially leading to unauthorized data exposure or remote code execution.

Proof of Concept (PoC):

An attacker provides a specially crafted input object containing a property path such as '\$<slot>__proto__.isAdmin=true' to the openapi-ts builder. The buildClientParams function merges this input into the prototype chain without filtering reserved object keys. Subsequent application logic that checks for administrative privileges will now return 'true' due to the polluted prototype, granting the attacker elevated access.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48819>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48819>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official

databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>